Загуглить противника

Как думать с помощью TI на примере 3CX

Компания / Имя спикера

УЧЕБНАЯ СИТУАЦИЯ · МАРТ 2023

После обновления защита предупредила.

Программа подписана. Можно продолжать?

Откроем улики по одной.

TI помогает выбрать следующий шаг

Сведения об угрозах помогают принимать решения по защите.

ВНЕШНИЕ СВЕДЕНИЯ

Что известно исследователям?

›

ОЦЕНКА ОСНОВАНИЙ

Что применимо к нашему событию?

›

СВОИ ДАННЫЕ

Чем это подтвердить у нас?

Сведения → оценка → следующая проверка

А. Вишняков · Ошибки TI в SOC, PHDays 2025 · А. Ненахов · Как киберразведка помогает SOC, 2023 · ссылки в заметках

Объект ещё нужно объяснить

IP

Сетевой адрес

ДОМЕН

Имя ресурса

URL

Ссылка с путём

SHA-256

Отпечаток файла

IoC — признак с основанием подозревать атаку.

Адрес в журнале:
наблюдаемый объект

› **Роль + источник + время:**
основание для проверки

NIST · Indicator of Compromise · Microsoft · Get-FileHash · ссылки в заметках

Совпадение — начало проверки

01
ТОТ ЛИ ОБЪЕКТ?

Имя или точные байты?

02
КАКАЯ РОЛЬ?

Роль объекта в исследовании

03
НА КАКУЮ ДАТУ?

Когда видели эту активность?

04
ЧТО БЫЛО У НАС?

Наличие?
Запуск?
Обращение?

Точный хеш может подтвердить известное содержимое.
Использование этого файла на устройстве проверяем отдельно.

SophosLabs · опубликованный SHA-256 · Microsoft · Authenticode · ссылки в заметках

Сначала вопрос. Затем сервис.

VirusTotal

Что известно об этом объекте?

- Точный объект и даты
- Содержание результатов
- Community → первоисточник

AbuseIPDB

Что сообщали об этом IP?

- Период и время жалобы
- Какая активность описана
- Сколько разных репортеров

Community даёт зацепку. Проверяем её по источнику.

Официальные документы VT / AbuseIPDB · Числа не равны вероятности · Полные ссылки в заметках

Одна иконка. Несколько компонентов.



3CXDesktopApp.exe

Чистый
основной файл



ffmpeg.dll

Изменённый код
с подписью 3CX



d3dcompiler_47.dll

Добавленная
скрытая нагрузка

СЛЕДУЮЩИЙ ВОПРОС

Где этот компонент был у нас?

ОПУБЛИКОВАННЫЙ SHA-256 КОНКРЕТНОГО ffmpeg.dll

```
c485674ee63ec8d4e8fde9800788175a8b02d3f9416d0e763360fff7f8eb4e02
```

Исторические сведения Sophos. Наше учебное устройство ещё не проверено.

Sophos · разбор 3CX, 2023 · SophosLabs · опубликованный SHA-256 · ссылки в заметках

Теперь — к своим устройствам

ПРИСУТСТВОВАЛ

Версия · путь · хеш

›

ИСПОЛНЯЛСЯ

Запуск · загрузка DLL

›

ОБРАЩАЛСЯ

Направление · процесс · время

ПОИСК ИЗВЕСТНОГО IoC

Где встречался этот точный хеш?

HUNTING-ГИПОТЕЗА

Что изменилось в поведении клиента после обновления?

Архивное упражнение: март–апрель 2023, при наличии данных. Кандидат требует проверки.

Sophos · разбор 3CX, 2023 · А. Ненахов · Как киберразведка помогает SOC, 2023 · ссылки в заметках

Что ответим сотруднику?

«Программа подписана. Можно продолжать?»

- Уточним предупреждение и компонент.
- Сверим источник, роль и время.
- Проверим историю устройства.

Объект › **Вопрос** › **Источник** › **Проверка** › **Действие**

Спасибо. Вопросы?